

Argus Vulnerability Report

All targets

Scan ID	all
Status	aggregated
Started	2026-08-20 20:27:34
Finished	2026-08-23 21:13:23
Generated	2026-08-24 21:21:09

Executive Summary

9	0	4	3	2	7	2	0
Total	Critical ≥8	High 6-8	Medium 4-6	Low <4	Confirmed	Suspected	Fixed

Severity Distribution by Type

Type	Count
RCE	0
SQLi	0
XSS	4
exposed_file	0
misconfig	5

Findings (9, sorted by severity)

6.0	XSS	http://127.0.0.1:8080/api/v1/auth/login
confirmed param_fuzz param: body.firebase_id_token open		

Reflected XSS in JSON body field 'firebase_id_token' via POST.

REQUEST EVIDENCE

POST http://127.0.0.1:8080/api/v1/auth/login Body: {"firebase_id_token": ""}

RESPONSE EVIDENCE

XSS marker reflected in response body

6.0 XSS http://127.0.0.1:8080/api/v1/auth/register

confirmed param_fuzz param: body.firebase_id_token open

Reflected XSS in JSON body field 'firebase_id_token' via POST.

REQUEST EVIDENCE

POST http://127.0.0.1:8080/api/v1/auth/register Body: {"firebase_id_token": ""}

RESPONSE EVIDENCE

XSS marker reflected in response body

6.0 XSS http://127.0.0.1:8080/api/v1/auth/signup

confirmed param_fuzz param: body.firebase_id_token open

Reflected XSS in JSON body field 'firebase_id_token' via POST.

REQUEST EVIDENCE

POST http://127.0.0.1:8080/api/v1/auth/signup Body: {"firebase_id_token": "", "display_name": "test", "organization_name": "test"}

RESPONSE EVIDENCE

XSS marker reflected in response body

6.0 XSS http://127.0.0.1:8080/api/v1/auth/token-active

confirmed param_fuzz param: body.firebase_id_token open

Reflected XSS in JSON body field 'firebase_id_token' via POST.

REQUEST EVIDENCE

POST http://127.0.0.1:8080/api/v1/auth/token-active Body: {"firebase_id_token": ""}

RESPONSE EVIDENCE

XSS marker reflected in response body

4.0 misconfig http://127.0.0.1:8000

confirmed api_discovery open

API surface discovery found 5 endpoint(s). Sources: options_probe. Paths: api/v1/auth/login, api/v1/auth/register, api/v1/query, api/v1/users, health

REQUEST EVIDENCE

Probed 10 spec paths + JS scraping + OPTIONS + brute-force

RESPONSE EVIDENCE

Discovered 5 API endpoint(s) across 5 unique paths

AI Fix Suggestion

[offline guidance] Misconfiguration: an endpoint or virtual host is accessible that likely shouldn't be exposed without authentication or at all in this environment. Fix by adding authentication/authorization middleware in front of administrative or internal-only routes, and auditing your routing/vhost config to ensure only intended hosts are served.

4.0 misconfig http://127.0.0.1:8080/docs

confirmed dir_enum open

Discovered accessible path at http://127.0.0.1:8080/docs (status 200, baseline was 404/22b).

REQUEST EVIDENCE

GET http://127.0.0.1:8080/docs

RESPONSE EVIDENCE

HTTP 200, 939 bytes

4.0 misconfig <http://127.0.0.1:8080>

confirmed api_discovery open

API surface discovery found 57 endpoint(s). Sources: openapi. Paths: api/v1/access-grants, api/v1/access-grants/my/connections, api/v1/access-grants/{access_id}, api/v1/access-grants/{access_id}/revoke, api/v1/auth/admin/logout/{target_uid}, api/v1/auth/login, api/v1/auth/logout, api/v1/auth/me, api/v1/auth/register, api/v1/auth/sessions...

REQUEST EVIDENCE

Probed 10 spec paths + JS scraping + OPTIONS + brute-force

RESPONSE EVIDENCE

Discovered 57 API endpoint(s) across 45 unique paths

2.0 misconfig <http://127.0.0.1:8080/api/v1/auth/token-active>

suspected param_fuzz param: body.[mass_assignment] open

Possible mass assignment vulnerability. Extra admin fields (role) appear to have been accepted by the server. Check for missing field whitelisting / allowlist validation.

REQUEST EVIDENCE

POST <http://127.0.0.1:8080/api/v1/auth/token-active> Body: {"firebase_id_token": "test", "is_admin": true, "role": "admin", "is_superuser": true, "admin": true, "role_id": 1, "permissions": ["admin", "write", "delete"], "is_staff": true, "privilege": "root"}

RESPONSE EVIDENCE

Status 200, fields ['role'] are top-level keys in JSON response

2.0 misconfig <http://127.0.0.1:8080/actuator/env>

suspected custom_rules param: /actuator/env open

Exposed Debug or Status Endpoint: A debug, health-check, or metrics endpoint is publicly reachable. These endpoints often expose sensitive internal state (environment variables, route maps, heap dumps, request logs). Restrict access to localhost or authenticated internal networks in production.

REQUEST EVIDENCE

GET http://127.0.0.1:8080/actuator/env Headers: {"Accept": "application/json, text/plain, */*"} Body:

RESPONSE EVIDENCE

Status 404 Content-Type: application/json Body snippet: {"detail":"Not Found"}